

Unauthorised Privilege Escalation response

Intrusion · **Critical** severity · SOC IR Playbook

Incident type	Access Control Violation / Privilege Misuse
Severity	Critical
Priority	Critical
Detection sources	SIEM, EDR, IAM logs, Sysmon, User Behaviour Analytics (UBA), Audit trails

Scenario

An attacker, either through a vulnerability, misconfiguration or stolen credentials, escalates privileges from a low-privilege user to an administrative or root-level account, potentially compromising critical systems or accessing sensitive data.

MITRE ATT&CK

T1068, T1078, T1548

Preparation

Implement RBAC and least privilege Ensure users only have necessary access Monitor privileged account activity Set up alerting for group membership changes and privilege elevation Log privilege escalation attempts Enable audit logs in Windows (Event ID 4670, 4672, 4728) and Linux (sudo logs, auditd) Conduct regular entitlement reviews Periodic reviews of admin rights and group memberships Harden endpoints Patch privilege escalation vulnerabilities and monitor for exploit attempts

Detection & Analysis

Identify privilege escalation alerts Unusual admin access, group changes or privilege tokens Correlate with user behaviour Check if the user normally has admin rights or elevated actions are expected Analyse process tree Look for unusual parent-child relationships (e.g., cmd.exe from Outlook) Validate persistence techniques Registry changes, scheduled tasks, services creation with elevated rights

Containment

Disable affected user accounts If elevation was unauthorised or compromised Terminate elevated sessions or processes Kill suspicious PowerShell, cmd or service processes Block IP or device If part of lateral movement or known attacker infrastructure Notify IT or HR If the user is internal and intent is unclear (malicious vs mistake)

Eradication

Revert permission changes Remove elevated rights, group memberships or access tokens Clean persistence mechanisms Remove scheduled tasks, registry modifications, service entries created by the attacker Patch exploited vulnerabilities Apply fixes for kernel-level or OS-level flaws (e.g., CVE-2021-36934) Review IAM policies and GPOs Address any inherited misconfigurations or unintended permission inheritance

Recovery

Re-enable legitimate users With correct access rights after review Restore affected systems If any configuration or data was altered during escalation Resume operations Once verified clean and secure Conduct post-remediation scan Confirm no backdoors or elevation paths remain

Lessons Learned & Reporting

Document full escalation path How the privilege was gained and what was accessed or modified Update SIEM detection rules For abnormal privilege changes, sensitive command execution Improve identity governance Enforce stricter access request and approval workflows Report if required Especially if data was accessed or tampered with Educate privileged users On the importance of proper access hygiene and security controls

Tools typically involved

SIEM (e.g., Splunk, Sentinel, QRadar); EDR (e.g., CrowdStrike, Cortex XDR, Microsoft Defender for Endpoint); IAM platforms (e.g., Azure AD, Okta, LDAP, Active Directory); Windows Event Logs (Security logs, Sysmon, GPO auditing); Linux audit tools (auditd, sudo logs); Threat Detection Rules (Sigma, KQL, YARA for suspicious privilege activity)

Success metrics (SLA targets)

Detection Time <5 minutes from escalation event Containment Time <30 minutes from confirmation Reversion Time <1 hour to remove elevated access Audit & RCA Completion Within 48 hours Privileged Account Review Completion 100% within 7 days post-incident